

01 / 联合评估

王者演武堂

源码与线上网站综合评估

用户阅读版 · 2026 年 9 月 6 日

已经有正式产品的外观和工程基础；当前最需要补齐的是登录入口、数据可信度和完整业务链路。

我的判断：修复关键入口后，适合组织熟人小范围试用。现在还不能仅凭新版界面或绿色 CI，认定为可稳定公开推广的版本。此次评估把线上已发生、源码可复现、尚待验证三种情况分别说明。

维度	当前判断
产品定位	清晰：好友内战组织、分路偏好与赛后复盘有明确价值
桌面体验	视觉统一、首页行动清楚；部分内容口径与导航仍需修正
移动入口	实测被错误重定向阻断，属于优先修复项
工程基础	分层、事务、上传边界、发布与诊断已具备
稳定性与权限	存在测试漏项、私有租约鉴权和耗时任务问题
正式验收	尚缺真机登录、完整比赛与 OCR、恢复演练证据

阅读顺序：第 2 页看手机故障和版本；第 3-8 页看产品、架构、安全、性能、数据和运维；第 9-10 页看验证边界与整改顺序。配套 MD 包含 R01-R12 的具体源码位置和验收要求。

证据来源：源码基线 | 线上网站

02 / 联合评估

手机故障：原因已定位，修复还差一步

线上运行的是 4afbecb；最新源码是 d0d45dd。最新提交修了设备跳转，但未登录跳转仍遗漏相同问题。

北京时间 9 月 6 日 17:13 左右，手机访问首页和登录页，服务器返回的 Location 是 https://localhost:8001/…。localhost 指访问者自己的设备，因此访问失败发生在到达正常页面之前。这与密码是否正确是两个不同环节。

测试入口	本次结果
桌面首页 /	200，可正常阅读首页
手机首页 /	307，跳到 localhost:8001/m
手机登录页 /login	307，跳到 localhost:8001/m/login
未登录桌面 /me	307，跳到 localhost:8001/login
线上版本标识	20260906080547-4afbecbe1316-262004

新版修复了什么？

新提交让设备重定向读取公网 Host 和转发协议，而不是直接使用内部请求地址。这个修复方向正确，本地设备路由测试也通过了。但认证分支仍用内部 req.url 构造登录地址，本地 /me 和 /m/me 场景均可复现遗漏。

正确的完成条件

统一所有重定向的公网地址处理后再发布；从公网域名验证手机首页、手机登录、未登录“我的”、登录后刷新和退出。健康接口的 releaseId 要对应完整修复版本。只更新源码或只看内部 health=200 都不够。

本次没有修改生产站点，也没有完成真实账号登录。手机结果来自手机 UA 的 HTTP 请求，不是真机浏览器认证测试。

证据来源：修复提交 | Middleware | 线上 health

产品与视觉：主线有价值，细节要兑现

最值得继续投入的方向

“喊朋友来 → 按分路和实力分队 → 打完留记录 → 下次再组局”是清楚的使用理由。首页文案、主按钮和好友内战氛围一致。英雄和装备图鉴可辅助查资料，但真正的差异应来自分队透明度、组织效率和比赛记录。

本次实际看到的优点

桌面首页采用深蓝与金色，峡谷背景没有压过主要操作。首页、列表和登录页的配色、圆角与组件语言统一。英雄图鉴显示 132 个条目，搜索李白后可以进入详情，查看基础属性、技能和皮肤。装备图鉴显示 121 个条目，名称搜索可用。条目数不是基础英雄或所有游戏模式的完整性证明。

体验问题	具体建议
登录账号叫“召唤师名称”	实际校验的是站内 username，容易让人误填游戏昵称；明确账号含义
装备文案承诺“看合成”	列表卡片没有详情动作，合成数据链路也未完整兑现；接通入口或收敛承诺
公告出现开发内部内容	把 src/web、features 等改为玩家能理解的变化，修复字面反斜杠换行
资讯夹杂其他游戏推广	按栏目和主题过滤，提高“峡谷情报”的相关性
长内容可读性	装备描述较密、字号偏小；可增加紧凑/展开模式并验证手机阅读

动效应服务于进房效率

开场已有跳过、减少动态效果设置、焦点管理和超时兜底，这是好的基础。下一步应减少重复访问的等待，不再优先增加装饰。移动端仍需软键盘、安全区和横竖屏测试，本次没有完整真机视觉通过结论。

证据来源：[首页](#) | [英雄详情](#) | [装备页面](#) | [登录页](#)

04 / 联合评估

架构与业务：基础扎实，边界仍有缝隙

基础能力	评价
代码分层	UI、业务、纯算法和基础设施分开，有自动检查；不是只在文档里画图
运行结构	Web 与 cron 分进程，现阶段模块化单体较合理
赛事容量	加入使用事务、冲突重试和 10 人上限，分队提交会再检查成员
比赛档案	截图、识别、人工确认、提交、异议和纠正已有明确模型
上传处理	视频流式写入，限制大小/类型/空闲时长，有临时文件清理

分层检查通过，不代表维护成本已经很低

src 下约 2.6 万行 TypeScript/TSX/CSS。globals.css 有 2,176 行，TournamentDetail.tsx 有 978 行；多个主题样式集中在根布局加载。部分 DTO 同时返回新旧字段，多处 any，部分 API Route 仍承载业务。这会让改一个页面时更容易影响别处。

建议继续沿现有分层拆分大型组件、表单状态和数据适配，建立明确 DTO 与统一错误处理。无需因为项目增长就马上迁移微服务或 Kubernetes。先解决能观测到的瓶颈。

历史记录与删除策略需要协调

数据库对比赛引用采用 Restrict，有助于保留历史。但旧的账号/赛事删除流程仍尝试直接删除，有档案时可能被外键拒绝，用户看到失败。应明确停用、匿名化、转移房主、归档和彻底删除的区别，返回业务提示；不应简单改成级联删除来消除错误。此处为源码风险，未在线删除数据验证。

文档版本也要一致

开发指南还写 Next.js 14，实际锁定为 15.5.23；package 版本 0.1.0 与公告 3.0.0 并存。产品版本和部署提交可以不同，但要有可解释的对应关系。

证据来源：架构说明 | 报名事务 | 数据模型 | 账号删除

05 / 联合评估

安全：已有基础防护，租约和认证需补齐

做得正确的部分

密码采用 bcrypt；会话使用加密封装、HttpOnly、SameSite，生产默认 Secure。权限从数据库实时读取，不单信 Cookie 里的角色。改密后的 sessionVersion 能使旧会话失效；只读鉴权不清 Cookie，减少旧请求误删新会话的竞争问题。

首要安全修复：私有资源租约不能只凭一个 leaseId 就持续读取或续期。

申请租约时检查登录，但读取、续期和释放 API 不重新检查当前用户；底层也只接收租约 ID。“赛事大厅”包含用户作用域资源，持有有效 ID 的请求可继续访问或延长租约，绕开原本的会话撤销逻辑。需要把资源归属、当前会话和封禁状态统一校验。

这个结论不代表外人已拿到数据，也不代表 UUID 可以轻易猜出。确认的是访问边界缺失；风险前提是持有有效租约 ID，原会话持有者也可能保留它。客户端主动清理不能替代服务端校验。

认证入口需要一致的反滥用策略

密码找回问答有限流，但登录、注册未见对应应用限流，仓库 Nginx 模板也未体现。重置密码确认分支还在验证 token 是否存在前执行昂贵哈希。应加账号/IP 组合限流、输入上限和明确的 429 提示，并确认代理传来的客户端 IP 可信。线上是否还有 WAF 等外层防护，本次未验证。

恢复与过期规则要讲清楚

Cookie 写了 90 天，但 iron-session 没显式设置 ttl，当前依赖默认封装有效期为 14 天，用户不能据注释预期三个月免登录。安全问题也不宜成为唯一长期恢复凭据。先对齐期限与撤销行为，再规划恢复码或已验证渠道。

证据来源：服务端鉴权 | 资源 API | 登录接口 | Session

性能与公平：不能只看算法能否算出结果

本地复现了输入差异导致的耗时差距

目前在 Web 请求中同步调用分队算法。最坏约需比较 181 万个候选；大家偏好相同或都未填写时，现有淘汰策略效果有限。下表是在本次评估环境 Node.js 24.19.0 的单次计算，不是你的云服务器跑分，也不是生产 p95。

十人输入场景	本次计算时间
都未填写分路偏好和战力	1,929 ms
分路优先级完全相同	2,429 ms
分路优先级轮转分散	22 ms

关键影响不是用户多等两秒：同步计算占住同一 Web 进程的事件循环，其他登录、API 和健康请求也可能被拖慢。仅把函数写成 `async` 并不会把 CPU 计算移到后台。

推荐的改法

使用有界工作线程池或独立任务进程；同一赛事避免重复计算，限制排队数量并保留超时预算。算法层再做偏好上界剪枝和减少对象分配。计算结果仍应确定、输入不被修改、成员变化时禁止提交旧结果。

“公平分队”的实际规则应透明

当前先最大化第一偏好人数，再第二偏好等；在偏好结果相同时才比较战力差。这意味着多满足一个人的第一偏好，可能优先于进一步缩小战力差。它是明确的产品选择，但不等于用户直觉中的“尽量五五开”。

战力由英雄战力、巅峰/分路指标的启发式公式计算，缺失项用中位数回填。建议在分队结果说明偏好满足情况、估计差距和未知数据，并用历史对局验证权重，不直接承诺胜率预测。

证据来源：搜索算法 | 比较规则 | 分队入口

数据与 OCR：用户需要可解释的最终结果

装备价格取了不同字段

线上列表当前展示上游 price，但没有展示 total_price，也未说明口径。官方装备数据本次抓取如下；若界面展示购买总价，应使用 total_price，并把其他口径分别标注。数据可能随版本和模式变化，以下是本次快照。

装备	线上 / price	上游 total_price
铁剑	165	275
末世	1260	2100
无尽战刃	1224	2060

同步代码还通过“值是否为真”决定更新属性，因此合法的 0 会被跳过：装备移除某项属性时，旧值可能残留，列表 JSON 与详情标量数据出现不一致。应区分零值、缺失和解析失败，统一字段与测试样本。

OCR 等待时间不一致

服务端允许 OCR 请求最多等待 90 秒，前端通用请求在 30 秒就中止。上游 35 秒完成时，用户可能先看到超时，后台随后才写入成功。更稳妥的方式是立即返回任务编号，后台识别，前端读取进度与最终状态，刷新后也能恢复。

“可选 OCR” 与正式提交要求冲突

环境模板把 OCR 标为可选，但正式比赛提交要求完成识别、六类截图和一致性校验。没有 OCR 配置时，人工填完也不能正常完成正式提交。应明确它是必需依赖，或设计带审计的人工提交模式。线上 OCR 是否配置、实际识别准确率，本次没有验证。

这部分建议先做闭环和容错，再追求更多识别字段：慢请求、重复点击、旧截图结果晚到、页面刷新，都应有可追踪状态。

证据来源：官方装备数据 | 装备同步 | OCR 服务 | 正式提交

08 / 联合评估

部署与运维：有回滚基础，还缺业务验证

线上健康状态的准确含义

检查项	本次结果
数据库 / 媒体 / 头像 / cron	ok
Redis	degraded
整体 HTTP / ok	200 / true

按代码，这是 Redis 配置后探测失败、且未设为必需依赖时的容错行为。不能据此断言密码写错，也不能把 200 理解成所有功能都正常。需要服务器侧核对连接与日志；若长期选择降级运行，也应有明确告警和性能基线。

当前发布设计值得保留

发布脚本先构建独立 release、备份数据库并运行迁移，再切换 current、启动/重载 PM2，校验版本与 cron 心跳，失败保留诊断。这比直接覆盖线上目录安全。但默认探测主要验证内部健康，没有证明公网重定向与真实登录可用。此次故障说明需要额外的公网业务 smoke。

回滚与备份必须覆盖真实业务资产

代码回滚不自动撤销数据库迁移，schema 要保持新旧版本兼容。数据库备份不等于媒体备份：头像、截图和视频同样需要保留与恢复策略。建议设异机备份、保留周期与定期恢复演练，确认恢复后的比赛记录还能打开原图。实际备份位置、磁盘规格和恢复结果，本次未读取。

给有限资源设预算

500 MiB 视频即使流式写入也占磁盘；需要用户/全站配额、磁盘低水位拒绝、失败文件清理和日志轮转。资源租约在进程内 Map，扩为多个 Web 实例前必须处理共享或去状态化；不能仅改 PM2 实例数。缓存淘汰后的用户条目元数据也应最终删除或受上限约束。

证据来源：健康接口 | 部署脚本 | 备份脚本 | 上传限制

09 / 联合评估

测试结果：通过项与未验证项分开看

验证项目	本次结论
最新 main 的 GitHub CI	成功；运行编号 34023173674
架构检查 / 类型检查	本地通过
核心 / 资源调度 / 会话契约测试	本地通过；不等于完整端到端认证
原有设备路由测试	通过；额外测试仍复现认证跳转遗漏
Lint	0 个错误、18 个警告，主要为原生 img 提示
生产依赖 npm audit	当时未报告已知漏洞；不覆盖业务逻辑漏洞
公网入口 / health	发现版本落后、localhost 跳转、Redis 降级
真机登录 / 上传 / OCR / 战术协作	未完成真实端到端验证
生产压测 / 数据库恢复	未执行；没有吞吐量或恢复时间承诺

为什么测试全绿还会出问题？

新设备路由脚本没有进入现有 CI。登录转场测试主要 mock 认证，并固定 Windows Chrome 路径，不能代表实际 Linux 反向代理、真实 Cookie 和移动浏览器。测试要检查完整路径，而不只是页面能渲染或接口返回成功。

建议新增一条专门的真实链路：隔离测试账号 → Nginx 公网形式 origin → 登录 → 访问“我的” → 刷新 → 退出 → 拒绝私有资源。让旧版的 localhost 跳转和租约撤销缺失都能触发失败。

本次工作边界

未改源码与生产服务，未提交账号密码、未创建赛事、未上传媒体；只读观察与本地模拟。源码是重点抽样，不是逐行无遗漏审计。本地没有重新执行完整构建与数据库集成，以该提交的 CI 结果作为补充证据。

证据来源：[CI 运行](#) | [CI 定义](#) | [登录转场测试](#)

下一步：把投入集中到完整使用链路

顺序	要完成的事	验收标志
第一批	修全公网跳转并发布；接入入口回归	手机和桌面认证入口通过，版本匹配
第二批	租约鉴权、认证限流、分队后台化	会话撤销生效，计算不阻塞普通请求
第三批	OCR 任务化、数据语义与零值修正	超时可恢复，比赛可完成提交，价格可解释
第四批	Redis 告警、备份恢复、归档/删除	依赖异常可发现，历史与媒体可恢复
持续改进	手机可用性、账号文案、组件与样式	真实场景少走弯路，修改影响范围可控

先跟踪四个业务指标

登录成功率、成功进房率、满员到分队完成的时间、比赛档案提交完成率。这四项能帮助判断产品是否真的可用。没有流量和行为数据之前，不急于讨论大规模并发、商业增长或复杂推荐算法。

公开发布前的最低完成条件

入口修复已在线上验证；真实账号登录/退出和失效会话通过；一场十人比赛从进房到档案提交走完；OCR不可用时明确路径；依赖失败能告警；数据库和媒体能够恢复。建议在隔离环境完成写操作验收后，再邀请熟人试用。

保留当前视觉与模块化架构，优先补齐可靠性、权限和数据口径。它已经值得继续做，但下一阶段应靠真实使用闭环证明成熟度。

配套开发文件：wzywt-codex-review-2026-09-06.md。它把本报告拆为 R01-R12，包含固定源码版本、证据、实现边界与可执行验收要求。

所有线上状态仅代表本次检查时刻。后续发布、配置变更和上游游戏版本更新，都需要重新验证相关结论。

证据来源：项目源码 | 评估版本